

GlobalTrust Financial Services

Enterprise Risk Management Framework

Enterprise Risk Management Office

Document ID	GTFS-RISK-001
Version	3.0
Classification	Confidential
Owner	Enterprise Risk Management Office
Approved By	Olivia Tan, Chief Risk Officer (CRO)
Approved By	Board Risk Committee
Effective Date	01 January 2026
Review Date	01 January 2027

Table of Contents

Executive Summary

1. Purpose

2. Scope

3. Governance Structure

4. Risk Appetite Statement

5. Enterprise Risk Categories

6. Risk Assessment Methodology

7. Risk Register

8. Risk Treatment Strategies

9. Key Risk Indicators (KRIs)

10. Risk Reporting

11. Third-Party Risk Management

12. Business Continuity & Crisis Management

13. Regulatory Compliance

14. Risk Culture

15. Frequently Asked Questions

16. Appendices

Executive Summary

GlobalTrust Financial Services (GTFS) operates a comprehensive Enterprise Risk Management (ERM) Framework aligned with ISO 31000 and COSO ERM principles. With 4,910 employees across Singapore, Dubai, Mumbai, and London, GTFS maintains a **Moderate** enterprise risk appetite, balancing growth objectives with prudent risk-taking.

- **Enterprise Risk Management philosophy** — Risk-informed decision-making embedded in strategy.
- **Board oversight** — Board Risk Committee meets Quarterly to review enterprise risk profile.
- **Strategic objectives** — Support revenue growth per GTFS-FIN-001 while protecting capital.
- **Risk appetite** — Moderate tolerance; Critical risks require Board Risk Committee approval.
- **Risk culture** — Mandatory risk training annually (8 hours) for all employees.
- **Operational resilience** — Target system availability of 99.95%; BCP per GTFS-BCP-001.

EXECUTIVE NOTE: The CRO reports directly to the Board Risk Committee with an independent reporting line to the Board of Directors, ensuring objective risk assessment.

1. Purpose

This Enterprise Risk Management Framework establishes the principles, governance, and processes by which GTFS identifies, assesses, treats, monitors, and reports risks. It complements the Company Overview (GTFS-EXEC-001), AML Policy (GTFS-COMP-001), KYC Guidelines (GTFS-COMP-002), and Information Security Policy (GTFS-SEC-001).

BOARD RECOMMENDATION: ERM is essential for banking organisations to protect stakeholders, maintain regulatory licences, and sustain long-term franchise value in volatile markets.

2. Scope

- Retail Banking, Commercial Banking, Corporate Banking, Mortgage Services.
- Treasury, Technology, Operations, Compliance, Legal, Human Resources.
- Customer Experience, Third-party Vendors, and all GTFS subsidiaries.
- Applies to all employees, contractors, and vendor relationships.

3. Governance Structure

Figure 1 — GTFS Risk Governance Structure

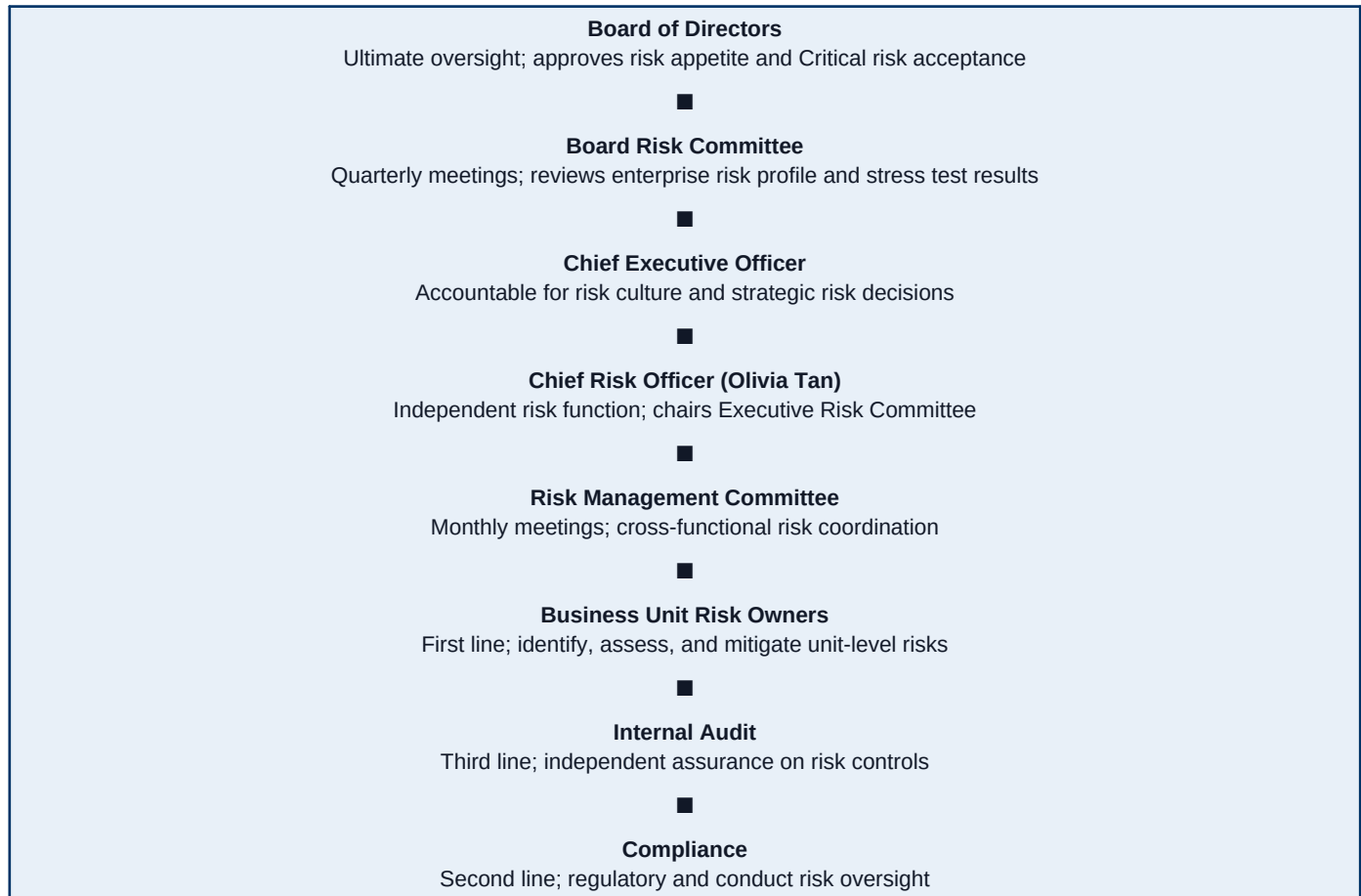


Figure 2 — Three Lines of Defense Model

First Line of Defense	Second Line of Defense	Third Line of Defense
Business units and operations Own and manage risk	ERM, Compliance, Legal Oversight and challenge	Internal Audit Independent assurance
Risk Owners Relationship Managers Technology Teams	CRO Office Compliance (GTFS-COMP-001) Information Security (GTFS-SEC-001)	Audit Committee reporting Annual risk-based audit plan

Body / Committee	Frequency	Primary Responsibilities
Board Risk Committee	Quarterly	Risk appetite; Critical risk acceptance; stress tests
Executive Risk Committee	Monthly	Enterprise risk profile; KRI review; escalation
Risk Register Review	Monthly	Validate register completeness and mitigation status
Enterprise Risk Assessment	Annually	Comprehensive risk identification and scoring
Business Impact Analysis	Every 2 years	Critical process and dependency mapping

4. Risk Appetite Statement

GTFS maintains a **Moderate** enterprise risk appetite. The Board Risk Committee approves the risk appetite statement annually and monitors adherence through quarterly reporting.

Risk Level	Definition	Acceptance Authority	Examples
Acceptable Risk	Within appetite; routine monitoring	Business Unit Risk Owner	Standard retail lending
Moderate Risk	Managed with controls; periodic review	CRO or delegate	New market entry
High Risk	Enhanced controls; executive oversight	Chief Risk Officer	Complex derivatives exposure
Critical Risk	Outside appetite; exceptional approval	Board Risk Committee	Major acquisition; systemic failure

RISK INSIGHT: Maximum risk acceptance authority: Chief Risk Officer for High Risk; Board Risk Committee for Critical Risk (score 20–25).

Risk Escalation Workflow



5. Enterprise Risk Categories

Strategic Risk

Market disruption, competitive pressure, M&A; integration failures.

Operational Risk

Process failures, human error, fraud losses; fraud dashboard reviewed Weekly.

Credit Risk

Loan defaults, counterparty failure; governed by GTFS-OPS-001 Loan Approval SOP.

Liquidity Risk

Funding gaps, market access constraints; stress tested Annually.

Market Risk

Interest rate, FX, and equity exposure in Treasury operations.

Cybersecurity Risk

Data breaches, ransomware; cyber dashboard reviewed Weekly per GTFS-SEC-001.

Technology Risk

System failures, legacy modernisation; target availability 99.95%.

Compliance Risk

Regulatory breaches; linked to GTFS-COMP-001 and GTFS-COMP-002.

Legal Risk

Litigation, contract disputes, regulatory enforcement actions.

Vendor Risk

Third-party failures; assessed before onboarding and Annually thereafter.

Reputation Risk

Negative publicity, customer trust erosion, ESG concerns.

Climate Risk

Physical and transition risks to loan portfolios and operations.

Business Continuity Risk

Disasters, pandemics; GTFS-BCP-001 Disaster Recovery Plan.

EMERGING RISK: Climate risk is an emerging risk category. The Board Risk Committee receives semi-annual climate risk updates starting FY2026.

Risk Category	Primary Owner	Linked Document	Primary KRI
Strategic	CEO / Strategy	GTFS-EXEC-001	Market share variance
Operational	COO	GTFS-OPS-001	Process failure rate
Credit	Head of Credit	GTFS-OPS-001 / GTFS-OPS-002	NP ratio
Liquidity	Treasurer	GTFS-FIN-001	LCR / NSFR
Market	Treasurer	GTFS-FIN-001	VaR utilisation
Cybersecurity	CISO	GTFS-SEC-001	Incidents (Weekly dashboard)
Technology	CTO	GTFS-SEC-001	System availability 99.95%
Compliance	CCO	GTFS-COMP-001 / GTFS-COMP-002	Regulatory findings
Vendor	Vendor Management	GTFS-SEC-003	SLA breaches
Business Continuity	COO / CRO	GTFS-BCP-001	RTO / RPO compliance

6. Risk Assessment Methodology

Figure 3 — Enterprise Risk Heat Map

Impact → Likelihood ↓	1 Negligible	2 Minor	3 Moderate	4 Major	5 Severe
1 Rare	1–2	2–4	3–6	4–8	5–10
2 Unlikely	2–4	4–6	6–9	8–12	10–15
3 Possible	3–6	6–9	9–12	12–16	15–20
4 Likely	4–8	8–12	12–16	16–20	20–25
5 Almost Certain	5–10	10–15	15–20	20–25	25

Score Ranges: Low 1–7 | Medium 8–14 | High 15–19 | Critical 20–25 (5 × 5 Risk Matrix Scale)

Score Range	Rating	Response Required
1–7	Low Risk	Standard controls; Business Unit Risk Owner monitors
8–14	Medium Risk	Documented mitigation plan; monthly KRI review
15–19	High Risk	CRO approval required; enhanced reporting
20–25	Critical Risk	Board Risk Committee approval; immediate action plan

Risk Assessment Process



Document

Update risk register within 5 business days

BEST PRACTICE: Scenario testing is conducted twice per year. Enterprise stress testing is performed Annually and reported to the Board Risk Committee.

7. Risk Register

The enterprise risk register is maintained by the ERM Office and reviewed Monthly. New risks must be logged within 5 business days of identification.

Risk ID	Description	Owner	L	I	Rating	Mitigation
R-001	Ransomware attack on core banking	CISO	3	5	15 (High)	In progress
R-002	Mortgage default spike — Dubai	Head of Mortgage	4	4	16 (High)	Active
R-003	Critical vendor cloud outage	CTO	3	4	12 (Med)	Complete
R-004	MAS regulatory finding — AML	CCO	2	4	8 (Med)	Active
R-005	Liquidity shortfall — stress	Treasurer	2	5	10 (Med)	Monitored
R-006	Key talent attrition — Tech	CHRO	4	3	12 (Med)	In progress
R-007	Data breach via third party	CISO	3	5	15 (High)	Active
R-008	Reputational damage — social media	CCO	3	3	9 (Med)	Monitored

8. Risk Treatment Strategies

Strategy	Description	When Applied	Approval
Avoid	Eliminate activity causing risk	Risk exceeds appetite	CRO / Board
Mitigate	Implement controls to reduce likelihood or impact	Most common approach	Risk Owner + CRO
Transfer	Insurance, hedging, outsourcing	Financial or operational transfer	CRO
Accept	Acknowledge within appetite	Low/Medium residual risk	Risk Owner
Monitor	Track via KRIs without immediate action	Emerging or stable risks	Risk Owner

Risk Treatment Matrix

Residual Rating	Avoid	Mitigate	Transfer	Accept	Monitor
Low (1–7)	Rarely	Optional	Optional	Common	Common
Medium (8–14)	Consider	Preferred	Consider	With CRO approval	With plan
High (15–19)	Preferred	Mandatory	Consider	CRO approval only	Not standalone
Critical (20–25)	Mandatory review	Mandatory + Board	Limited	Board only	Insufficient

BOARD RECOMMENDATION: Risk acceptance without a documented treatment plan is prohibited for Medium, High, and Critical residual risks.

9. Key Risk Indicators (KRIs)

KRI	Threshold	Dashboard	Owner
Cybersecurity incidents	≤ 2 major / quarter	Weekly	CISO
Fraud losses	< 0.05% of revenue	Weekly	Head of Fraud
System downtime	Availability ≥ 99.95%	Monthly (Ops)	CTO
Customer complaints	< 500 / month	Monthly	Head of CX
Vendor failures	Zero critical SLA breach	Monthly	Vendor Mgmt
Compliance findings	Zero material findings	Monthly	CCO
Loan defaults (NPL)	< 2.5% portfolio	Monthly	Head of Credit
Employee turnover	< 12% annualised	Monthly	CHRO

RISK INSIGHT: KRI breaches trigger automatic escalation. Critical incidents require notification within 30 minutes; major incident reviews within 24 hours.

10. Risk Reporting

Report	Audience	Frequency	Content
Executive Risk Dashboard	CEO, CRO, ExCo	Monthly	Top 10 risks, KRI status, incidents
Board Risk Report	Board Risk Committee	Quarterly	Risk profile, appetite, stress tests
Operational Risk Report	Risk Management Committee	Monthly	Loss events, control failures
Cyber Risk Dashboard	CRO, CISO, CTO	Weekly	Threats, vulnerabilities, incidents
Fraud Dashboard	CRO, CCO, Fraud team	Weekly	Losses, typologies, investigations
Incident Escalation	Per severity matrix	Ad hoc	Critical: 30 min; Major review: 24 hr

11. Third-Party Risk Management

Third-party risk assessment is mandatory **before onboarding and annually thereafter**. Critical vendors undergo review every 6 months.

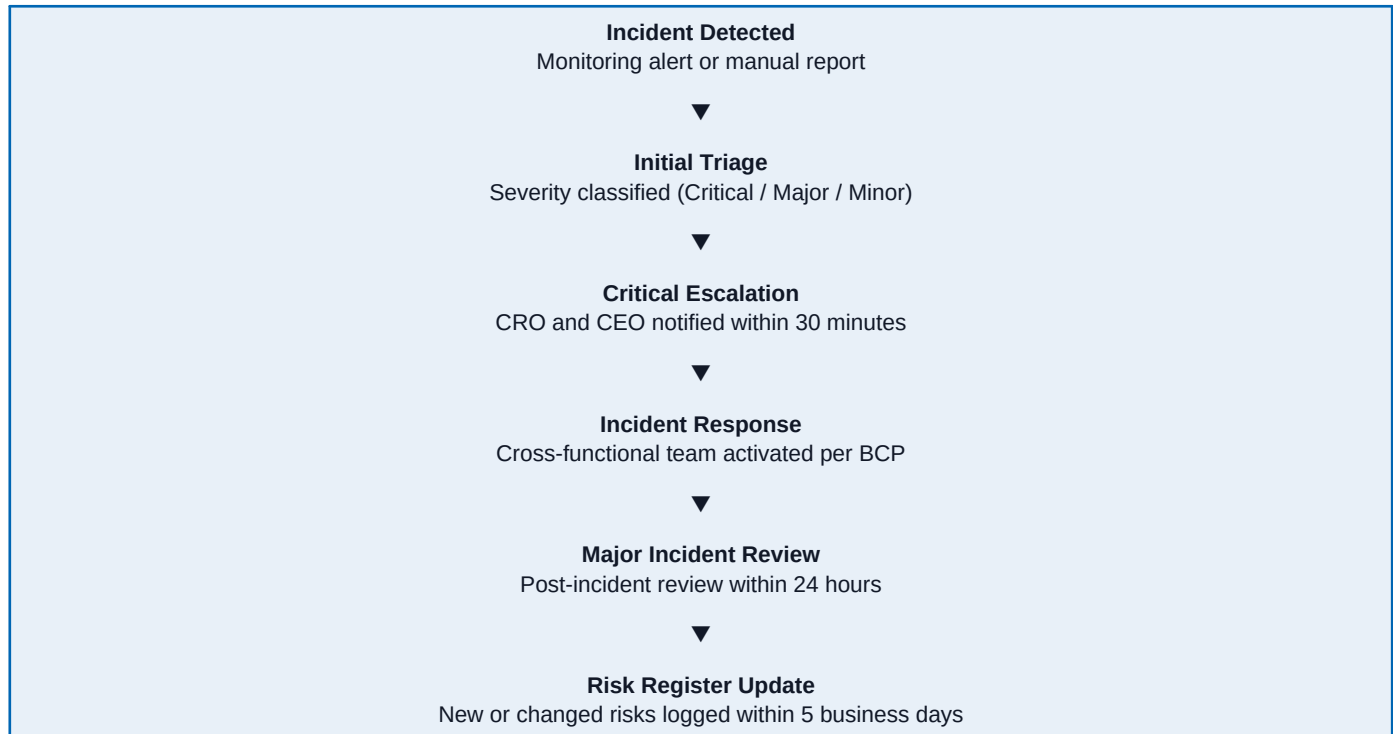
Vendor Tier	Examples	Due Diligence	Review Frequency
Critical	Core banking, cloud hosting, payment providers	Full assessment + security review	Every 6 months
High	Data processors, KYC providers	Security questionnaire + onsite	Annually
Medium	SaaS tools, office suppliers	Standard questionnaire	Annually
Low	Non-data vendors	Basic screening	At contract renewal

BEST PRACTICE: Vendor security reviews must align with GTFS-SEC-001 and GTFS-SEC-003 VPN Access Guide for remote vendor access.

12. Business Continuity & Crisis Management

- **Operational resilience** — Critical services recover within RTO targets per GTFS-BCP-001.
- **Disaster Recovery** — Dual data centre architecture; failover tested twice per year.
- **Pandemic response** — Remote work per GTFS-HR-002 Remote Work Policy.
- **Data centre outage** — Automatic failover; incident command within 30 minutes.
- **Cyber incident response** — Playbooks aligned with GTFS-SEC-001; CRO notified immediately.

Incident Escalation Process



13. Regulatory Compliance

Standard / Regulation	Application	GTFS Alignment
MAS (Singapore)	Primary regulator; risk governance notices	Board Risk Committee charter
ISO 31000	Risk management principles and guidelines	ERM Framework structure
COSO ERM	Enterprise risk integration with strategy	Three lines of defense model
ISO 27001	Information security management	GTFS-SEC-001 alignment
Banking Regulations	RBI, DFSA, FCA local requirements	Regional risk procedures

14. Risk Culture

Role	Responsibilities
All Employees	Report risks; complete mandatory training (8 hours annually)
Managers	Embed risk awareness; escalate breaches promptly
Executives	Accountability for unit risk profile and culture
CRO	Independent challenge; enterprise risk reporting to Board
Board Risk Committee	Set appetite; oversee Critical risk decisions

EXECUTIVE NOTE: Risk awareness is a continuous improvement priority. Employee feedback on risk processes is collected through the annual culture survey.

Enterprise Risk Case Studies

Case Study: Major Cyberattack

Scenario: Sophisticated ransomware attempt targeting GTFS core banking infrastructure in Singapore.

Risk Assessment: Inherent score 20 (Critical); residual 12 (Medium) after controls.

Mitigation: Activated cyber incident response; isolated affected systems; notified MAS within regulatory timeline.

Residual Risk: Medium — enhanced monitoring for 12 months; weekly cyber dashboard.

Lessons Learned: Accelerated zero-trust rollout per GTFS-SEC-001; Critical incident escalated within 30 minutes.

Case Study: Cloud Outage

Scenario: Primary cloud provider experienced 4-hour regional outage affecting digital banking channels.

Risk Assessment: Inherent score 16 (High); residual 8 (Medium) after DR failover.

Mitigation: Failover to secondary region per GTFS-BCP-001; customer communications issued.

Residual Risk: Medium — vendor placed on enhanced monitoring; Critical vendor review in 6 months.

Lessons Learned: Confirmed 99.95% availability target not met for the month; vendor SLA penalty invoked.

Case Study: Vendor Data Breach

Scenario: Third-party KYC provider reported unauthorised access to customer verification data.

Risk Assessment: Inherent score 18 (High); residual 10 (Medium) after remediation.

Mitigation: Suspended vendor integration; forensic review; customer notification per regulatory requirements.

Residual Risk: Medium — vendor risk reclassified to Critical; 6-month review cycle.

Lessons Learned: Reinforced third-party assessment before onboarding and annually thereafter.

Case Study: Mortgage Default Spike

Scenario: Dubai mortgage portfolio NPL ratio increased from 1.8% to 3.2% over two quarters.

Risk Assessment: Inherent score 14 (Medium); residual 10 (Medium) with enhanced underwriting.

Mitigation: Tightened lending criteria per GTFS-OPS-002 Mortgage Processing Guide.

Residual Risk: Medium — monthly credit KRI monitoring; quarterly Board reporting.

Lessons Learned: Linked credit risk to macroeconomic scenario in annual enterprise stress testing.

Case Study: Regulatory Finding

Scenario: MAS inspection identified gaps in transaction monitoring aligned to GTFS-COMP-001.

Risk Assessment: Inherent score 12 (Medium); residual 6 (Low) after remediation plan.

Mitigation: Remediation programme with 90-day milestones; CCO accountable.

Residual Risk: Low — quarterly Compliance KRI tracking until closed.

Lessons Learned: Cross-reference between ERM, AML Policy, and KYC Guidelines strengthened.

Case Study: Liquidity Crisis (Stress Scenario)

Scenario: Annual enterprise stress test modelled severe funding market disruption.

Risk Assessment: Inherent score 22 (Critical) in stress scenario; residual 14 (Medium) with contingency funding.

Mitigation: Activated contingency funding plan; Treasury hedging increased.

Residual Risk: Medium under normal conditions; Critical under stress — Board Risk Committee informed.

Lessons Learned: Liquidity risk appetite reviewed; HQLA buffer increased per GTFS-FIN-001 budget allocation.

15. Frequently Asked Questions

Q: What is GTFS enterprise risk appetite?

A: Moderate — balancing growth with prudent risk-taking.

Q: What risk matrix scale does GTFS use?

A: 5 × 5 — Likelihood (1–5) × Impact (1–5).

Q: What is a Critical risk score?

A: 20–25 on the enterprise risk matrix.

Q: What is a High risk score?

A: 15–19.

Q: What is a Medium risk score?

A: 8–14.

Q: What is a Low risk score?

A: 1–7.

Q: How often does the Board Risk Committee meet?

A: Quarterly.

Q: Executive Risk Committee frequency?

A: Monthly.

Q: How often is the risk register reviewed?

A: Monthly.

Q: Enterprise risk assessment frequency?

A: Annually.

Q: Business Impact Analysis frequency?

A: Every 2 years.

Q: Vendor risk review frequency?

A: Annually; Critical vendors every 6 months.

Q: Cyber risk dashboard frequency?

A: Weekly.

Q: Operational risk dashboard frequency?

A: Monthly.

Q: Fraud dashboard frequency?

A: Weekly.

Q: Risk training requirement?

A: Mandatory annually — 8 hours for all employees.

Q: Target system availability?

A: 99.95%.

Q: Who approves High risk acceptance?

A: Chief Risk Officer.

Q: Who approves Critical risk acceptance?

A: Board Risk Committee.

Q: Critical incident escalation timeline?

A: Within 30 minutes.

Q: Major incident review timeline?

A: Within 24 hours.

Q: Risk register update SLA?

A: Within 5 business days after identifying a new risk.

Q: Scenario testing frequency?

A: Twice per year.

Q: Enterprise stress testing frequency?

A: Annually.

Q: Third-party risk assessment timing?

A: Before onboarding and annually thereafter.

16. Appendices

Appendix A — Enterprise Risk Register (Summary)

Refer to Section 7 for the live register. All entries require Risk Owner sign-off.

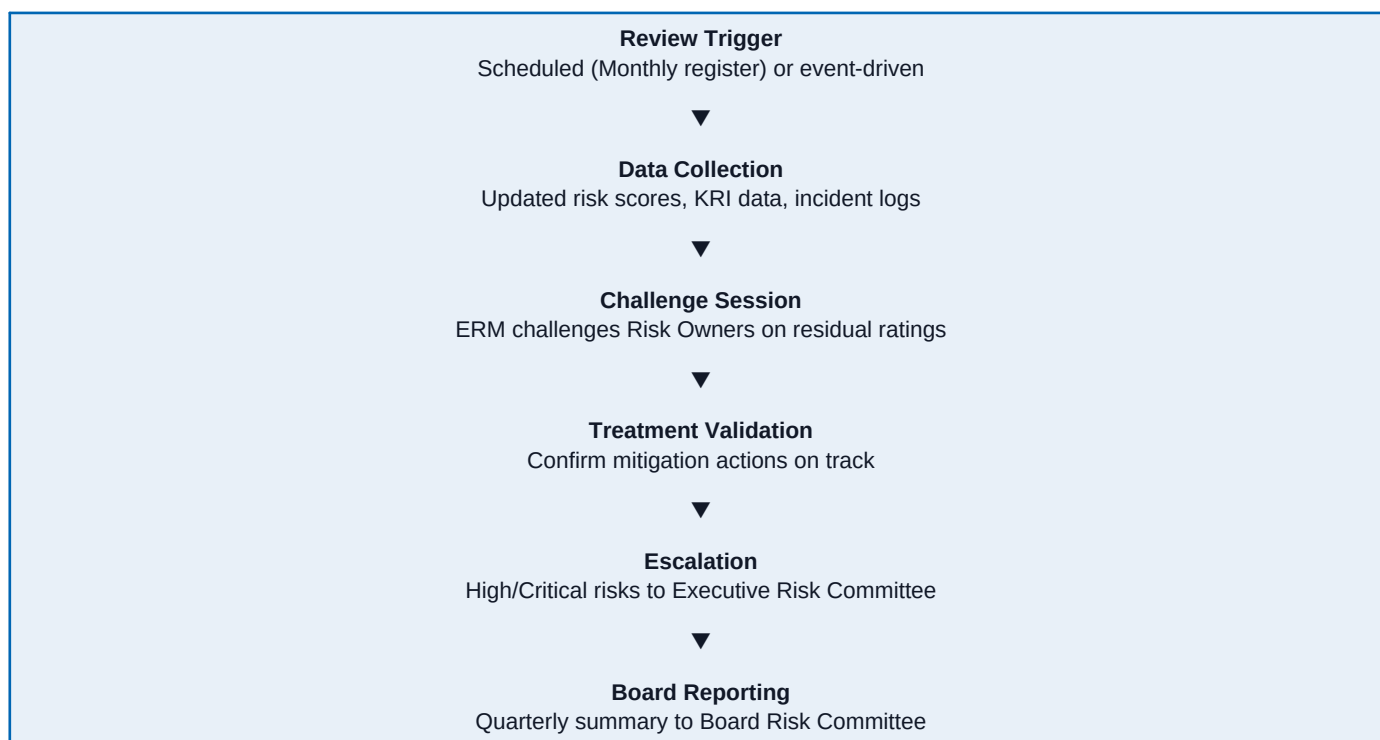
Appendix B — Risk Appetite Matrix

Category	Acceptable	Moderate	High	Critical
Credit	Retail standard	Commercial lending	Structured finance	Concentrated exposure
Operational	Process variance	System degradation	Major outage	Core banking failure
Cyber	Minor phishing	Contained breach	Data exfiltration	Systemic compromise
Compliance	Administrative	Procedural gap	Regulatory finding	Licence threat

Appendix C — Risk Heat Map

Refer to Figure 3 in Section 6. Score ranges: Low 1–7, Medium 8–14, High 15–19, Critical 20–25.

Appendix C.1 — Periodic Review Process



Appendix C.2 — Governance Responsibilities

Governance Body	Risk Appetite	Risk Assessment	Risk Reporting	Risk Acceptance
Board of Directors	Approve	Oversee	Receive	Critical only
Board Risk Committee	Monitor	Review	Receive	Critical
CEO	Champion	Accountable	Receive	Delegate to CRO

Governance Body	Risk Appetite	Risk Assessment	Risk Reporting	Risk Acceptance
CRO	Propose	Lead	Prepare	High
Business Unit Risk Owners	Adhere	Conduct	Contribute	Low/Medium
Internal Audit	Assess	Assure	Report	N/A

Appendix D — Risk Committee Structure

Refer to Figures 1 and 2 in Section 3.

Appendix E — Glossary

Term	Definition
ERM	Enterprise Risk Management
KRI	Key Risk Indicator
Inherent Risk	Risk level before controls are applied
Residual Risk	Risk level after controls are applied
Risk Appetite	Level of risk GTFS is willing to accept
Risk Tolerance	Maximum acceptable variation from appetite
Three Lines of Defense	Operational, oversight, and assurance model
Stress Testing	Simulation of adverse scenarios on capital and liquidity

Appendix F — ERM Office Contacts

Function	Contact
Enterprise Risk Management Office	erm@gtfs.internal
Chief Risk Officer	cro@gtfs.com
Risk Register queries	risk-register@gtfs.internal
Incident escalation hotline	+65 8000 9200

Document Control

Document ID: GTFS-RISK-001 | Version 3.0 | Classification: Confidential

Approved By: Olivia Tan, CRO; Board Risk Committee | Effective: 01 January 2026 | Review: 01 January 2027

Generated: 28 June 2026